

US Patent & Trademark Office

Patent Public Search | Text View

United States Patent Application Publication

20250284841

Kind Code

A1

Publication Date

September 11, 2025

Inventor(s)

MURUGESAN; Mummoorthy et al.

SYSTEMS AND METHODS FOR DETECTING RISK EVENTS IN A COMPUTING ENVIRONMENT USING INFRASTRUCTURE GRAPHS AND EVEN LOG SCANNERS

Abstract

The technology disclosed relates to a system and method for detecting risk events in a cloud environment that obtains a set of risk signature definitions and deploys an event log scanner to the cloud environment. The event log scanner is configured to detect instances of candidate risk events in accordance with the set of risk signature definitions based on a scan of an event log and to label each detected instance with a signature identifier. Result metadata is received indicative of the detected instances. A cloud infrastructure graph is accessed that defines nodes that represent resources in the cloud environment and edges, between the nodes, that represent relationships between the resources. Context information is derived from the cloud infrastructure graph based on the result metadata. An output is generated representing a classification of one or more of the detected instances of candidate risk events as a risk event based on the context information relative to the set of risk signature definitions.

Inventors: MURUGESAN; Mummoorthy (Gilroy, CA), Kallur; Bharath S (Bangalore, IN), ITHAL; Ravishankar Ganesh (Los Altos, CA), Singh; Abhinav (Sunnyvale, CA)

Applicant: Proofpoint, Inc. (Sunnyvale, CA)

Family ID: 94371927

Assignee: Proofpoint, Inc. (Sunnyvale, CA)

Appl. No.: 19/194926

Filed: April 30, 2025

Foreign Application Priority Data

IN	202311050873	Jul. 28, 2023
----	--------------	---------------

Related U.S. Application Data

Publication Classification

Int. Cl.: G06F21/62 (20130101); G06F21/55 (20130101); G06F21/56 (20130101)

U.S. Cl.:

CPC G06F21/6245 (20130101); G06F21/554 (20130101); G06F21/566 (20130101);

Background/Summary

CROSS-REFERENCE TO RELATED APPLICATIONS [0001] The present application is a continuation of and claims priority to U.S. patent application Ser. No. 18/781,121, filed Jul. 23, 2024, which is based on and claims the benefit of Indian application Ser. No. 20/231,1050873, filed Jul. 28, 2023; the contents of these applications are hereby incorporated by reference in their entirety.

FIELD OF THE TECHNOLOGY DISCLOSED

[0002] The technology disclosed generally relates to cloud environments. More specifically, but not by limitation, the present disclosure relates to improved systems and methods of cloud security posture management (CSPM), cloud infrastructure entitlement management (CIEM), cloud-native application protection platform (CNAPP), cloud-native configuration management database (CMDB), and/or data security posture management (DSPM).

BACKGROUND

[0003] The subject matter discussed in this section should not be assumed to be prior art merely as a result of its mention in this section. Similarly, a problem mentioned in this section or associated with the subject matter provided as background should not be assumed to have been previously recognized in the prior art. The subject matter in this section merely represents different approaches, which in and of themselves can also correspond to implementations of the claimed technology.

[0004] Cloud computing provides on-demand availability of computer resources, such as data storage and compute resources, often without direct active management by users. Thus, a cloud environment can provide computation, software, data access, and storage services that do not require end-user knowledge of the physical location or configuration of the system that delivers the services. In various examples, remote servers can deliver the services over a wide area network, such as the Internet, using appropriate protocols, and those services can be accessed through a web browser or any other computing component.

[0005] Examples of cloud storage services include Amazon Web Services™ (AWS), Google Cloud Platform™ (GCP), and Microsoft Azure™, to name a few. Such cloud storage services provide on-demand network access to a shared pool of configurable resources. These resources can include networks, servers, storage, applications, services, etc. The end-users of such cloud services often include organizations that have a need to store sensitive and/or confidential data, such as personal information, financial information, medical information. Such information can be accessed by any of a number of users through permissions and access control data assigned or otherwise defined through administrator accounts.

[0006] The discussion above is merely provided for general background information and is not intended to be used as an aid in determining the scope of the claimed subject matter.

SUMMARY

[0007] The technology disclosed relates to analysis of security posture of a cloud environment. In particular, the disclosed technology relates to a system and method for detecting risk events in a cloud environment that obtains a set of risk signature definitions and deploys an event log scanner to the cloud environment. The event log scanner is configured to detect instances of candidate risk events in accordance with the set of risk signature definitions based on a scan of an event log and to label each detected instance with a signature identifier that identifies one or more risk signatures that corresponds to the detected instance. Result metadata is received indicative of the detected instances and, based on the result metadata, context information associated with the detected instances is obtained based on a cloud infrastructure graph. An output is generated representing a classification of one or more of the detected instances of candidate risk events as a risk event based on the context information relative to the set of risk signature definitions.

[0008] This Summary is provided to introduce a selection of concepts in a simplified form that are further described below in the Detailed Description. This Summary is not intended to identify key features or essential features of the claimed subject matter, nor is it intended to be used as an aid in determining the scope of the claimed subject matter. The claimed subject matter is not limited to implementations that solve any or all disadvantages noted in the background.

Description

BRIEF DESCRIPTION OF THE DRAWINGS

[0009] In the drawings, like reference characters generally refer to like parts throughout the different views. Also, the drawings are not necessarily to scale, with an emphasis instead generally being placed upon illustrating the principles of the technology disclosed. In the following description, various implementations of the technology disclosed are described with reference to the following drawings, in which:

[0010] FIG. 1 is a block diagram illustrating one example of a cloud architecture.

[0011] FIG. 2 is a block diagram illustrating one example of a cloud service.

[0012] FIG. 3 is a block diagram illustrating one example of a cloud security posture analysis system.

[0013] FIG. 4 is a block diagram illustrating one example of a deployed scanner.

[0014] FIG. 5 is a flow diagram showing an example operation of on-boarding a cloud account and deploying one or more scanners.

[0015] FIG. 6 illustrates one example of a user interface display having a dashboard representing on-boarded cloud service accounts.

[0016] FIG. 7 is a flow diagram illustrating one example of cloud infrastructure scanning performed by a cloud scanner deployed in a cloud service.

[0017] FIGS. 8-1 and 8-2 (collectively referred to as FIG. 8) provide a flow diagram illustrating one example of infrastructure analysis and query execution.

[0018] FIG. 9 illustrates an example user interface display.

[0019] FIG. 10 is a schematic diagram of a cloud environment.

[0020] FIGS. 11-1 and 11-2 (collectively referred to as FIG. 11) provide a flow diagram illustrating one example of operation of an orchestration engine.

[0021] FIG. 12-1 illustrates rules filtering criteria for risk signatures, in one example.

[0022] FIG. 12-2 illustrates example matching logic actions.

[0023] FIG. 13 is a flow diagram illustrating one example of operation of an event log scanner.

[0024] FIG. 14 illustrates one example of a user interface display that renders a set of tagged risk signatures.

[0025] FIG. 15 illustrates one example of a user interface display that renders instances of matched

risk signatures.

[0026] FIG. **16** illustrates one example of a user interface display that renders categorized risk events.

[0027] FIG. **17** is a simplified block diagram of one example of a client device.

[0028] FIG. **18** illustrates an example of a handheld or mobile device.

[0029] FIG. **19** shows an example computer system.

DETAILED DESCRIPTION

[0030] The following discussion is presented to enable any person skilled in the art to make and use the technology disclosed, and is provided in the context of a particular application and its requirements. Various modifications to the disclosed implementations will be readily apparent to those skilled in the art, and the general principles defined herein may be applied to other implementations and applications without departing from the spirit and scope of the technology disclosed. Thus, the technology disclosed is not intended to be limited to the implementations shown, but is to be accorded the widest scope consistent with the principles and features disclosed herein.

[0031] As noted above, cloud computing environments are used by organizations or other end-users to store a wide variety of different types of information in many contexts and for many uses. This data can often include sensitive and/or confidential information, and can be the target for malicious activity such as acts of fraud, privacy breaches, data theft, etc. These risks can arise from individuals that are both inside the organization as well as outside the organization.

[0032] Cloud environments often include security infrastructure to enforce access control, data loss prevention, or other processes to secure data from potential vulnerabilities. However, even with such security infrastructures, it can be difficult for an organization to understand the data posture and breadth of access to the data stored in the cloud in the organization's cloud account. In other words, it can be difficult to identify which users have access to which data, and which data may be exposed to malicious or otherwise unauthorized users, both inside or outside the organization.

[0033] The present disclosure is directed to a cloud security posture analysis system. In some described examples, a system and/or method obtains a set of risk signature definitions, each risk signature definition representing a corresponding risk signature, generates an event log scanner configured to detect, in a cloud environment, instances of candidate risk events in accordance with the risk signature definitions and to label each detected instance with a signature identifier that identifies one or more risk signatures, of the set of risk signatures, that corresponds to the detected instance, deploys the event log scanner to a cloud environment, receives result metadata indicative of the detected instances of candidate risk events, obtains, based on the result metadata, context information associated with the detected instances of candidate risk events based on a cloud infrastructure graph that defines nodes that represent resources in the cloud environment and edges, between the nodes, that represent relationships between the resources, and classifies one or more of the detected instances of candidate risk events as a risk event based on the result metadata and the context information relative to the set of risk signature definitions.

[0034] FIG. **1** is a block diagram illustrating one example of a cloud architecture **100** in which a cloud environment **102** is accessed by one or more actors **104** through a network **106**, such as the Internet or other wide area network. Cloud environment **102** includes one or more cloud services **108-1**, **108-2**, **108-N**, collectively referred to as cloud services **108**. As noted above, cloud services **108** can include cloud storage services such as, but not limited to, AWS, GCP, Microsoft Azure, to name a few.

[0035] Further, cloud services **108-1**, **108-2**, **108-N** can include the same type of cloud service, or can be different types of cloud services, and can be accessed by any of a number of different actors **104**. For example, as illustrated in FIG. **1**, actors **104** include users **110**, administrators **112**, developers **114**, organizations **116**, and/or applications **118**. Of course, other actors **120** can access cloud environment **102** as well.

[0036] Architecture **100** includes a cloud security posture analysis system **122** configured to access cloud services **108** to identify and analyze cloud infrastructure and data security posture within cloud environment **102**. Examples of system **122** are discussed in further detail below. Briefly, however, system **122** is configured to access cloud services **108** and identify cloud infrastructure assets, such as by identifying connected resources, entities, actors, etc. within those cloud services, and to identify risks and violations against access to sensitive information. As shown in FIG. 1, system **122** can reside within cloud environment **102** or outside cloud environment **102**, as represented by the dashed box in FIG. 1. Of course, system **122** can be distributed across multiple items inside and/or outside cloud environment **102**.

[0037] Users **110**, administrators **112**, developers **114**, or any other actors **104**, can interact with cloud environment **102** through user interface displays **123** having user interface mechanisms **124**. For example, a user can interact with user interface displays **123** provided on a user device (such as a mobile device, a laptop computer, a desktop computer, etc.) either directly or over network **106**. Cloud environment **102** can include other items **125** as well.

[0038] FIG. 2 is a block diagram illustrating one example of cloud service **108-1**. For the sake of the present discussion, but not by limitation, cloud service **108-1** will be discussed in the context of an account within AWS. Of course, other types of cloud services and providers are within the scope of the present disclosure.

[0039] Cloud service **108-1** includes a plurality of resources **126** and an access management and control system **128** configured to manage and control access to resources **126** by actors **104**. Resources **126** include compute resources **130**, storage resources **132**, and can include other resources **134**. Compute resources **130** include a plurality of individual compute resources **130-1**, **130-2**, **130-N**, which can be the same and/or different types of compute resources. In the present example, compute resources **130** can include elastic compute resources, such as elastic compute cloud (AWS EC2) resources, AWS Lambda, etc.

[0040] An elastic compute cloud (EC2) is a cloud computing service designed to provide virtual machines called instances, where users can select an instance with a desired amount of computing resources, such as the number and type of CPUs, memory and local storage. An EC2 resource allows users to create and run compute instances on AWS, and can use familiar operating systems like Linux, Windows, etc. Users can select an instance type based on the memory and computing requirements needed for the application or software to be run on the instance.

[0041] AWS Lambda is an event-based service that delivers short-term compute capabilities and is designed to run code without the need to deploy, use or manage virtual machine instances. An example implementation is used by an organization to address specific triggers or events, such as database updates, storage changes or custom events generated from other applications. Such a compute resource can include a server-less, event-driven compute service that allows a user to run code for many different types of applications or backend services without provisioning or managing servers.

[0042] Storage resources **132** are accessible through compute resources **130**, and can include a plurality of storage resources **132-1**, **132-2**, **132-N**, which can be the same and/or different types of storage resources. A storage resource **132** can be defined based on object storage. For example, AWS Simple Storage Service (S3) provides highly-scalable cloud object storage with a simple web service interface. An S3 object can contain both data and metadata, and objects can reside in containers called buckets. Each bucket can be identified by a unique user-specified key or file name. A bucket can be a simple flat folder without a file system hierarchy. A bucket can be viewed as a container (e.g., folder) for objects (e.g., files) stored in the S3 storage resource.

[0043] Compute resources **130** can access or otherwise interact with storage resources **132** through network communication paths based on permissions data **136** and/or access control data **138**. System **128** illustratively includes identity and access management (IAM) functionality that controls access to cloud service **108-1** using entities (e.g., IAM entities) provided by the cloud

computing platform.

[0044] Permissions data **136** includes policies **140** and can include other permissions data **142**. Access control data **138** includes identities **144** and can include other access control data **146** as well. Examples of identities **144** include, but are not limited to, users, groups, roles, etc. In AWS, for example, an IAM user is an entity that is created in the AWS service and represents a person or service who uses the IAM user to interact with the cloud service. An IAM user provides the ability to sign into the AWS management console for interactive tasks and to make programmatic requests to AWS services using the API, and includes a name, password, and access keys to be used with the API. Permissions can be granted to the IAM user to make the IAM user a member of a user group with attached permission policies. An IAM user group is a collection of IAM users with specified permissions. Use of IAM groups can make management of permissions easier for those users. An IAM role in AWS is an IAM identity that has specific permissions, and has some similarities to an IAM user in that the IAM role is an AWS identity with permission policies that determine what the identity can and cannot do in AWS. However, instead of being uniquely associated with one person, a role is intended to be assumable by anyone who needs it. Roles can be used to delegate access to users, applications, and/or services that don't normally have access to the AWS resources. Roles can be used by IAM users in a same AWS account and/or in different AWS accounts than the role. Also, roles can be used by compute resources **130**, such as EC2 resources. A service role is a role assumed by a service to perform actions in an account on behalf of a user. Service roles include permissions required for the service to access the resources needed by the service. Service roles can vary from service to service. A service role for an EC2 instance, for example, is a special type of service role that an application running on an EC2 instance can assume to perform actions.

[0045] Policies **140** can include identity-based policies that are attached to IAM identities can grant permissions to the identity. Policies **140** can also include resource-based policies that are attached to resources **126**. Examples include S3 bucket policies and IAM role trust policies. An example trust policy includes a JSON policy document that defines the principles that are trusted to assume a role. In AWS, a policy is an object that, when associated with an identity or resource, defines permissions of the identity or resource. AWS evaluates these policies when an IAM principal user or a role) makes a request. Permissions in the policy determine whether the request is allowed or denied. Policies are often stored as JSON documents that are attached to the IAM identities (user, groups of users, role).

[0046] A permissions boundary is a managed policy for an IAM identity that defines the maximum permissions that the identity-based policies can grant to an entity, but does not grant the permissions. Further, access control lists (ACLs) control which principles in other accounts can access the resource to which the ACL is attached. ACLs can be similar to resource-based policies. In some implementations of the technology disclosed, the terms “roles” and “policies” are used interchangeably.

[0047] Cloud service **108-1** includes one or more deployed cloud scanners **148**, cloud provider application programming interface(s) (APIs) **150**, a data store **152**, an event log generation component **154**, and can include other items **156** as well. Cloud scanner **148** run locally on the cloud-based services and the server systems, and can utilize elastic compute resources, such as, but not limited to, AWS Lambda resources. Cloud scanner **148** is configured to access and scan the cloud service **108-1** on which the scanner is deployed. Examples are discussed in further detail below. Briefly, however, a scanner accesses the data stored in storage resources **132**, permissions data **136**, and access control data **138** to identify particular data patterns (such as, but not limited to, sensitive string patterns) and traverse or trace network communication paths between pairs of compute resources **130** and storage resources **132**. The results of the scanner can be utilized to identify subject vulnerabilities, such as resources vulnerable to a breach attack, and to construct a cloud attack surface graph or other data structure that depicts propagation of a breach attack along the network communication paths.

[0048] Given a graph of connected resources, such as compute resources **130**, storage resources **132**, etc., entities (e.g., accounts, roles, policies, etc.), and actors (e.g., users, administrators, etc.), risks and violations against access to sensitive information is identified. A directional graph can be built to capture nodes that represent the resources and labels that are assigned for search and retrieval purposes. For example, a label can mark the node as a database or S3 resource, actors as users, administrators, developers, etc. Relationships between the nodes are created using information available from the cloud infrastructure configuration. For example, using the configuration information, system **122** can determine that a resource belongs to a given account and create a relationship between the policy attached to a resource and/or identify the roles that can be taken up by a user.

[0049] Event log generation component **154** is configured to generate event logs **158** (also referred to as activity logs), which record actions taken by a user, a role, or a cloud service as events. Component **154**, in one example, is configured to deploy a database log generator on each of a plurality of databases **162** on storage resources **132**. Databases **162** can store information in any of a plurality of different types of structures. For example, some or all databases **162** can comprise structured query language (SQL) databases that store and organize data in tables with related information. Each table consists of rows and columns, with each row representing a record and each column representing a specific data field. SQL databases allow users to manipulate data through SQL commands. Some examples of SQL databases include MySQL and PostgreSQL, to name a few. Alternatively, or in addition, some or all databases **162** can include non-SQL databases.

[0050] The respective event log generator, for each respective database **162**, generates a respective database log in event logs **158**. An example log includes log entries that record the database activities, events, etc. Example logs include, but not limited to, audit logs, transaction logs, etc.

[0051] As noted above, in some examples, resources **126** can include AWS EC2 and/or Lambda resources. Also, resources **126** can include AWS Instance Stores and/or AWS Elastic Block Store (EBS) volumes. An EBS volume is a durable, block-level storage device that can attach to a compute instance and used as a physical hard drive.

[0052] Resources **126** can also include an Azure blob identified by a resource URL syntax that assigns each resource a corresponding base URL.

[0053] A cloud storage service or cloud service provider (CSP) can include an organization which hosts services such as networking, software, servers, and/or infrastructure, among others. A CSP can also provide security for the provided services. The services provided by the CSP can relieve a client organization of individual responsibility of setting and managing infrastructure. Examples of CSPs include Amazon Web Services™, Microsoft Azure™, Salesforce™, Google Cloud platform™, among others.

[0054] Cloud provider APIs **150** are configured to receive calls to access various components in cloud service **108**. For example, cloud provider APIs **150** can access event logs **158** stored in data store **152**. Data store **152** can also store other data items **160** as well.

[0055] A CSP generally provides a number of different interfaces to cloud-computing services, such as a service-provider interface to organizational clients for computing services. A CSP, for example, provides interfaces that allow cloud-computing clients to launch virtual machines, application programs, and other computational entities. A CSP can also provide user interface that allow claims to access, through the Internet, the services provided by the CSP. A client of the CSP can deploy web servers to access, modify, and sending information.

[0056] A cloud account provided by a CSP includes roles that determine user privileges users and what actions can be taken in the cloud account. An identify and access management (IAM) role is managed by the CSP and provides predefined roles that give granular access to specific CSP resources and prevent unwanted access to other CSP resources. For instance, an AWS IAM role includes an AWS identity with a set of permissions policies that each determine what the role can

do within an AWS account. An IAM role can be assumed by anyone who needs requires the role. [0057] FIG. 3 is a block diagram illustrating one example of cloud security posture analysis system 122. As noted above, system 122 can be deployed in cloud environment 102 and/or access cloud environment 102 through network 106 shown in FIG. 1.

[0058] System 122 includes a cloud account onboarding component 202, a cloud scanner deployment component 204, a cloud data scanning and analysis system 206, a visualization system 208, and a data store 210. System 122 can also include a database connection component 212, one or more processors or servers 214, and can include other items 215 as well.

[0059] Cloud account onboarding component 202 is configured to onboard cloud services 108 for analysis by system 122. After onboarding, cloud scanner deployment component 204 is configured to deploy a cloud scanner (e.g., deployed cloud scanner(s) 148 shown in FIG. 2) to the cloud service. In one example, the deployed scanners are on-demand agent-less scanners configured to perform agent-less scanning within the cloud service. One example of an agent-less scanner does not require agents to be installed on each specific device or machine. The scanners operate on resources 126 and access management and control system 128 directly within the cloud service, and generate metadata that is returned to system 122. Thus, in one example, the actual cloud service data is not required to leave the cloud service for analysis.

[0060] Cloud data scanning and analysis system 206 includes a metadata ingestion component 216 configured to receive the metadata generated by the deployed cloud scanner(s) 148. System 206 also includes a query engine 218, a policy engine 220, a breach vulnerability evaluation component 222, one or more application programming interfaces (APIs) 224, a cloud security issue identification component 226, a cloud security issue prioritization component 228, a risk event detection system 230, and can include other items 232 as well.

[0061] Query engine 218 is configured to execute queries against the received metadata and generated cloud security issue data. Policy engine 220 can execute security policies against the cloud data and breach vulnerability evaluation component 222 is configured to evaluate potential breach vulnerabilities in the cloud service. APIs 224 are exposed to users, such as administrators, to interact with system 122 to access the cloud security posture data.

[0062] Component 226 is configured to identify cloud security issues and component 228 can prioritize the identified cloud security issues based on any of a number of criteria.

[0063] Visualization system 208 is configured to generate visualizations of the cloud security posture from system 206. Illustratively, system 208 includes a user interface component 234 configured to generate a user interface for a user, such as an administrator. In the illustrated example, component 234 includes a web interface generator 236 configured to generate web interfaces that can be displayed in a web browser on a client device.

[0064] Visualization system 208 also includes an infrastructure graph generator component 238, a cloud attack surface graph generator component 240, and can include other items 242 as well. Infrastructure graph generator component 238 is configured to generate a graph or other representation of the relationships between resources 126 or other infrastructure assets such as privileges, roles, etc. For example, component 238 can generate a cloud infrastructure graph, such as a map, that graphically depicts pairs of compute resources and storage resources as nodes and network communication paths as edges between the nodes.

[0065] Cloud attack surface graph generator component 240 is configured to generate a surface graph or other representation of vulnerabilities of resources to a breach attack. In one example, the representation of vulnerabilities can include a cloud attack surface map that graphically depicts propagation of a breach attack along network communication paths as edges between nodes that represent the corresponding resources.

[0066] Data store 210 stores metadata 244 obtained by metadata ingestion component 216, sensitive data profiles 246, detected event logs 248, and can store other items 250 as well. Examples of sensitive data profiles 246 are discussed in further detail below. Briefly, however,

sensitive data profiles **246** can identify target data patterns that are to be categorized as sensitive or conforming to a predefined pattern of interest. Sensitive data profiles **246** can be used as training data for data classification. Examples of data classification are discussed in further detail below. For instance, however, pattern matching can be performed based on the target data profiles. Illustratively, pattern matching can be performed to identify instances of data patterns corresponding to social security numbers, credit card numbers, other personal data, medical information, to name a few. In one example, artificial intelligence (AI) is utilized to perform named entity recognition (e.g., natural language processing modules can identify sensitive data, in various languages, representing names, company names, locations, etc.).

[0067] Database connection component **212** is configured to connect to, or access, databases in the data stores of the resources being analyzed by system **122**. Examples are discussed in further detail below. Briefly, however, database connection component **212** can receive user access credentials, such as a username and password, for each database of a plurality of databases to be accessed in the cloud environment and scanned by the deployed scanners. In another example, database connection component **212** can be configured to connect to representations of the databases that are accessed using a different authentication requirement, than the databases themselves. For example, database connection component **212** can identify and connect to snapshots of the databases through cloud provider APIs **150**, discussed above. Database connection component **212** can access event logs **158**, for the identified databases, from data store **152**.

[0068] Risk event detection system **230** includes a trigger detection component **252**, an orchestration engine configuration component **254**, an event log scanner configuration component **256**, an action generator component **258**, a post processing component **259**, and can include other items **260** as well.

[0069] Operation of system **230** is discussed in further detail below. Briefly, however, trigger detection component **252** is configured to detect a triggering criterion corresponding to initiation of risk event detection of cloud environment **102**. For example, the risk event detection can be initiated for one or more cloud accounts associated with a given user.

[0070] Orchestration engine configuration component **254** configures an orchestration engine (e.g., a control plane) that is configured to deploy configured event log scanners to the cloud account(s) to scan event logs in those accounts. For example, the orchestration engine can deploy a plurality of microservices to analyze event logs in parallel. Examples of event logs include, but are not limited to, database activity logs.

[0071] An example orchestration engine includes a tool or platform that automates and manages the deployment, configuration, coordination, and monitoring of complex applications or services. The orchestration engine can provide a centralized control system that streamlines the management of multiple components and resources, such as containerized applications, across distributed systems. In addition, the orchestration engine can include features such as load balancing, automatic failover, and resource allocation to help ensure that the application is highly available and can scale dynamically to handle changing workloads. In one example, each microservice is configured to perform a specific function that is deployable and scalable independently of other services. The deployed event log analyzer microservice(s) return analysis results to the orchestration engine, such as in the form of metadata from the event logs.

[0072] Event log scanner configuration component **256** is configured to implement an event log scanner to parse one or more event logs in the cloud environment, match parsed entries in the event logs against risk signatures, and return results to the orchestration engine. Accordingly, component **256** includes a risk signature component **262**, a matching logic component **264**, and a results component **266**. Risk signature component **262** is configured to obtain a set of risk signatures and to generate metadata representing those risk signatures, as inputs to be used as matching criterion for matching logic (e.g., a rules engine) implemented by matching logic component **264**. A particular example of risk signature metadata generated for a risk signature indicates an RDS

service (i.e., asset type) with a sharing operation (i.e., target action).

[0073] An example matching logic (also referred to as a rules engine) is configured to filter events in the event log with specific properties in the event. In one example, the rules engine applies generic logic (that is generic to a set of risk signatures and/or the different types of events in the event log) to combine context from other resources, such as an infrastructure graph. The generic logic can extract details from the event to perform multi-level matching against the risk signature metadata to identify risky events (i.e., candidate risk events that have some threshold correspondence to the risk signatures). The multi-level matching identifies a number of inputs from a given event from the event log that matches risk signature metadata for a given risk signature. If a threshold number of matches are identified, the given event is identified as a candidate risk event relative to the given risk signature. Examples of inputs include cloud provider identification (e.g., AWS, etc.), asset/service type (e.g., S3, RDS, IAM, etc.), and/or operations or actions of interest that occur within the cloud environment and are to be identified as candidate risk events.

[0074] The rules engine is configured to detect, in the cloud environment, instances of candidate risk events in accordance with the risk signature definitions and to label each detected instance with a signature identifier that identifies one or more risk signatures, of the set of risk signatures identified by component **262**, that correspond to the detected instance. The scanner generates result metadata indicative of the detected instances of candidate risk events that are returned using results component **266**.

[0075] Action generator component **258** identifies one or more actions to take based on the results metadata. For example, action generator component **258** can include a post processing component **259** configured to perform post-processing that obtains context information based on the result metadata, for example from an infrastructure graph. In another example, a user interface display is generated to indicate detected risk events and/or perform remedial actions based on the risk events, etc.

[0076] FIG. **4** is a block diagram illustrating one example of a deployed scanner **148**. Scanner **148** includes a resource identification component **402**, a permissions data identification component **404**, an access control data identification component **406**, a cloud infrastructure scanning component **408**, a cloud data scanning component **410**, an output component **412**, an event log scanner component **414**, and can include other items **416** as well. FIG. **4** also illustrates that some or all components of and/or functionality performed by system **230** can be on or otherwise associated with deployed scanner **148**.

[0077] Resource identification component **402** is configured to identify the resources **126** within cloud service **108-1** (and/or other cloud services **108**) and to generate corresponding metadata that identifies these resources. Permissions data identification component **404** identifies the permissions data **136** and access control data identification component **406** identifies access control data **138**. Cloud infrastructure scanning component **408** scans the infrastructure of cloud service **108** to identify the relationships between resources **130** and **132** and cloud data scanning component **410** scans the actual data stored in storage resources **132**. Output component **412** is configured to output the generated metadata and content-based classification results to cloud security posture analysis system **122**.

[0078] The metadata generated by scanner **148** can indicate a structure of schema objects in a data store. For example, where the schema objects comprise columns in a data store having a tabular format, the returned metadata can include column names from those columns. A content-based data item classifier is configured to classify data items within the schema objects, based on content of those data items. Examples are discussed in further detail below.

[0079] Event log scanner component **414** is configured to analyze event log(s) to identify candidate risk events. An example candidate risk event includes an event that has a threshold level of matching to a predefined risk signature. For example, a candidate risk event can include an RDS service having a sharing operation. As discussed in further detail below, post-processing operations

can determine, using context information, whether the candidate risk event is considered an actual risk event. For sake of illustration, in the above example of a detected event of an RDS service with a sharing operation, the context information can indicate whether the RDS service includes sensitive data and/or the sharing operation shared data with a publicly accessible resource, etc. Put another way, the additional post-processing steps are utilized to determine whether some or all of the candidate risk events are identified as actual risk events based on the risk signatures (or can be discarded as false risk events) and/or whether to perform subsequent actions.

[0080] Component **414** includes a log parser component **418**, a multi-level matching component **420**, a risk signature tag generator **422**, a result output component **424**, and can include other items **426** as well.

[0081] Briefly, the parsing can be done in any of a number of ways. In one example, log parser component **418** accesses each of a number of entries in the event log and identifies constituent data fields that identify various characteristics or parameters from a respective event or activity in the cloud environment. For example, the parsing can include an identification of what service (e.g., a resource or other asset) had a change, a time that the change occurred, what geographic region the change occurred in, what entity was involved in the change (e.g., a requestor identity), as well as any other attributes. These attributes can be returned as metadata by result output component **424**.

[0082] Multi-level matching component **420** is configured to perform a multi-level (or input) matching operation to match inputs provided from the matching logic against the event log entries, to identify candidate risk events. In one example, component **424** includes a call function **428** configured to call or invoke an event log entry analyzer that obtains objects from the event log and performs further processing to determine whether the event log has a threshold level match against the risk signature criterion.

[0083] Risk signature tag generator **422** is configured to identify the risk signature (or multiple risk signatures) that are matched to the given event log entry, and to generate a risk signature tag that is added to the results metadata. In this way, the orchestration engine or control plane can identify which risk signatures were satisfied in obtaining the candidate risk event. As discussed below, each risk signature can have a globally unique identifier, that uniquely identifies the risk signature from other risk signatures in the set of risk signatures. This global unique identifier can be added (or a representation of the identifier) to the metadata that is returned by result output component **424**.

[0084] FIG. 5 is a flow diagram **500** showing an example operation of system **122** in on-boarding a cloud account and deploying one or more scanners. At block **502**, a request to on-board a cloud service to cloud security posture analysis system **122** is received. For example, an administrator can submit a request to on-board cloud service **108-1**.

[0085] At block **504**, an on-boarding user interface display is generated. At block **505**, user input is received that defines a new cloud account to be on-boarded. The user input can define a cloud provider identification **506**, a cloud account identification **508**, a cloud account name **510**, access credentials to the cloud account **512**, and can include other input **514** defining the cloud account to be on-boarded.

[0086] At block **516**, the cloud account is authorized using roles. For example, administrator access (block **518**) can be defined for the cloud scanner using IAM roles. One or more cloud scanners are defined at block **520** and can include, but are not limited to, cloud infrastructure scanners **522**, cloud data scanners **524**, vulnerability scanners **526**, event log scanners **528**, or other scanners **530**.

[0087] At block **532**, the cloud scanners are deployed to run locally on the cloud service, such as illustrated in FIG. 2. The cloud scanners discover resources at block **534**, scan data in the resources at block **536**, event logs at block **538**, and can find vulnerabilities at block **540**. As discussed in further detail below, a vulnerability can be identified based on finding a predefined risk signature in the cloud service resources. The risk signatures can be queried upon, and define expected behavior within the cloud service and locate anomalies based on this data.

[0088] At block **542**, if more cloud services are to be on-boarded, operation returns to block **504**.

At block **544**, the scan results from the deployed scanners are received. As noted above, the scan results include metadata (block **546**) and/or data item classifications (block **548**) generated by the scanners running locally on the cloud service.

[0089] At block **550**, one or more actions are performed based on the scan results. At block **552**, the action includes security issue detection. For example, a breach risk on a particular resource (such as a storage resource storing sensitive data) is identified. At block **554**, security issue prioritization can be performed to prioritize the detected security issues. Examples of security issue detection and prioritization are discussed in further detail below. Briefly, security issues can be detected by executing a query against the scan results using vulnerability or risk signatures.

[0090] The risk signatures identify criterion such as accessibility of the resources, access and/or permissions between resources, and data types in accessed data stores. Further, each risk signature can be scored and prioritized based on impact. For example, a risk signature can include weights indicative of likelihood of occurrence of a breach and impact if the breach occurs.

[0091] A risk signature can be defined based upon any of a wide variety of criteria. For example, a risk signature can identify one or more configurations or settings of compute resources **130**. Examples include, but are not limited to, a configuration that indicates whether the compute resource provides accessibility to a particular type of data, such as confidential data, medical data, financial data, personal data, or any other type of private and/or sensitive content. In another example, a risk signature indicates that a compute resource is publicly accessible, includes a public Internet protocol (IP) address, or has IP forwarding enabled. In another example, a risk signature indicates that a compute resource has monitoring disabled, has no IAM role assigned to the compute resource, has backup disabled, data encryption disabled, and/or a low or short backup retention policy. Also, a risk signature can identify password policies set for the compute resource. For instance, a risk signature can indicate a lack of minimum password policies, such as no minimum password length, no requirement of symbols, lowercase letters, uppercase letters, numbers, or password reuse policy. Also, a risk criterion can indicate a location of the compute resource, such as whether the compute resource is located outside of a particular region.

[0092] Risk signatures can also indicate configurations and/or settings of storage resources **132**. For example, the configurations and settings can indicate authentication or permissions enforced by the storage resource, such as whether authentication is required for read, write, delete, synchronization, or any other operation. Also, the risk signature can indicate whether multi-factor authentication is disabled for the storage resource, as well as a breadth of permissions grants (e.g., whether all authenticated users are granted permissions within the storage resource). Also, a risk signature can indicate whether encryption is enabled by default, a password policy enforced by the storage resource, whether the storage resource is anonymously accessible, publicly accessible, has a key management service disabled, has logging disabled, life cycle management disabled, whether the storage resource is utilized for website hosting, has geo-restriction disabled, or has backup functionality disabled. Also, the risk signature can indicate a type of data stored by the storage resource, such as the examples discussed above.

[0093] The action can further include providing user interfaces at block **556** that indicate the scan status (block **558**), a cloud infrastructure representation (such as a map or graph) (block **560**), and/or a cloud attack surface representation (map or graph) (block **562**). The cloud attack surface representation can visualize vulnerabilities.

[0094] Remedial actions can be taken at block **564**, such as creating a ticket (block **566**) for a developer or other user to address the security issues. Of course, other actions can be taken at block **568**. For instance, the system can make adjustments to cloud account settings/configurations to address/remedy the security issues.

[0095] FIG. **6** illustrates one example of a user interface display **600**, that can be displayed at block **552**. Display **600** provides a dashboard for a user which provides an overview of on-boarded cloud service accounts. The dashboard identifies a number of users **602**, a number of assets **604**, a

number of data stores **606**, and a number of accounts **608**. A data sensitivity pane **610** includes a display element **612** that identifies a number of the data stores that include sensitive data, a display element **613** that identifies a number of users with access to the sensitive data, a display element **614** that identifies a number of resources having sensitive data, and a display element **616** that identifies a number of risks on the data stores having sensitive data. Further, graphs or charts can be generated to identify those risks based on factors such as status (display element **618**) or impact (display element **620**).

[0096] Display element **620** illustratively categorizes the risks based on impact as well as the likelihood of occurrence of those risks. Risk categorization is discussed in further detail below. Briefly, however, display element **620** stratifies one or more of breach likelihood scores or breach impact scores categories representing different levels of severity, such as high, medium, and low severity levels. In one example, display element **620** is color coded based on the degree of impact of the risk (e.g., high impact is highlighted in red, medium impact is highlighted in yellow, and low impact is highlighted in green).

[0097] FIG. 7 is a flow diagram **700** illustrating one example of cloud infrastructure scanning performed by cloud scanner **148** deployed in cloud service **108-1**. At block **702**, an agent-less scanner is executed on the cloud service. For example, a compute resource can utilize a serverless function to perform a scan on the cloud service.

[0098] At block **704**, the scanner discovers the compute resources **130** and, at block **706**, the storage resources **132**. Sensitive data can be discovered at block **708**. The agent-less scanner does not require a proxy or agent running in the cloud service, and can utilize server-less containers and resources to scan the documents and detect sensitive data. The data can be accessed using APIs associated with the scanners. The sensitive data can be identified using pattern matching, such as by querying the data using predefined risk signatures.

[0099] At block **710**, access paths between the resources are discovered based on permissions data **136** (block **712**), and/or access control data **138** (block **714**). A rule processing engine, such as using JSON metadata, can be utilized to analyze the roles and policies, and can build access relationships between the nodes representing the resources. The policies can be decoded to get access type (allow, deny, etc.) and the policy can be placed in a node to link from a source to target node and create the access relationship. At block **716**, metadata indicative of the scanning results is generated and outputted by metadata output component **272**.

[0100] FIGS. 8-1 and 8-2 (collectively referred to as FIG. 8) provide a flow diagram **800** illustrating one example of infrastructure analysis and query execution. At block **802**, permissions data and access control data for pairs of compute and storage resources is accessed. Policy data is accessed at block **804**. For example, the policy data can include identity-based policies (block **806**), resource-based policies (block **808**), permissions boundaries (block **810**), service control policies (SCP) (block **812**), session policies (block **814**) as well as other policies (block **816**).

[0101] At block **818**, network communication paths are traced between the pairs of resources. Tracing the network communication path can be based on the permissions data at block **820**, the access control data at block **822**, the policy data at block **824**, and/or other data at block **826**.

[0102] At block **828**, a cloud infrastructure map is constructed. An example of a cloud infrastructure map includes nodes that graphically represent pairs of compute and storage resources (block **830**), and edges that represent network communication paths between the resources (block **832**). At block **834**, the map graphically depicts metadata associated with the pairs of resources. For example, a graphical metadata depiction is expandable or collapsible via user selection, as represented at block **836**. The metadata can be grouped across metadata categories at block **838**, such as based on cloud-sourced metadata at block **840**, derived metadata at block **842**, locally annotated metadata at block **844**, or based on other metadata categories at block **846**.

[0103] The cloud infrastructure map can also graphically depict anomalous configured access instances at block **848**. For example, block **848** can detect different levels of access among

resources that connect to a common network component, as represented at block **850**. At block **852**, the map graphically depicts anomalous actual access instances in the cloud environment. For instance, the instances can be detected from access logs at block **854**. User annotated tags for the resources can be depicted in the map at block **856** as well.

[0104] At block **858**, a query is received. The query can include a search term, a content category, a data privacy policy, a temporal period, and can include other items as well.

[0105] Alternatively, or in addition, a filter criterion is received can be received at block **860**. The filter criterion can be based on the metadata, based on applications running on at least one pair of resources, and/or based on one or more networks in the cloud environment.

[0106] The query and/or filter criterion are executed at block **862** and results are returned at block **864**. For example, the query results can identify a subset of the pairs of resources that contain searched content.

[0107] FIG. **9** illustrates a user interface display **900** that includes a visualization of cloud infrastructure assets and relationships between those assets, such as access communication paths. The visualization in FIG. **9** can be rendered as a cloud infrastructure graph (e.g., map) that shows relationships between compute and storage resources and/or mappings between users, roles, and resources, based on the permissions data and the access control data. Further, the visualization can be augmented using sensitivity classification data to represent propagation of breach attack along communication paths.

[0108] As shown in FIG. **9**, nodes **902** represent compute resources and nodes **904** represent storage resources. Illustratively, the storage resources include data stores or buckets within a particular cloud service. Nodes **906** represent roles and/or users. The links (e.g., access paths) or edges **908** between nodes **902** and **906** represent that compute resources that can access the particular roles represented by nodes **906**. The edges or links **910** represent the storage resources that can be accessed by the particular roles or users represented by nodes **906**.

[0109] Based on these relationships between compute and storage relationships, display elements can be rendered along, or otherwise visually associated with, the edges **908** and/or **910**, to identify and graphically depict the propagation of breach attack. For instance, vulnerability display elements can be rendered in association with edges **908** and/or **910** to identify that a subject vulnerability signature (e.g., one or more risk signatures shown in FIG. **9**) has been identified in the data, based on querying the permissions and access control data using the subject vulnerability signature. For example, display element **909** represents a risk signature between nodes **903** and **912** and display element **911** represents (such as by including a description, icon, label, etc.) a risk signature between nodes **912** and **922**. Each display element **909**, **911** can represent (such as by including a description, icon, label, etc.) corresponding likelihood and impact scores, can be actuatable to render details of the subject vulnerability, such as in a display pane on display **900**. The details can include which risk signature has been matched, which sensitive data is at risk, etc.

[0110] FIG. **10** is a schematic diagram of a cloud environment **1000** including a plurality of cloud accounts **1002-1**, **1002-N** (collectively referred to as cloud accounts **1002**). An orchestration engine **1004** is configured by orchestration engine configuration component **254**. FIG. **10** will be discussed in the context of FIG. **11**, which provides a flow diagram **1100** illustrating one example of operation of orchestration engine **1004**.

[0111] At block **1102**, a set of risk signatures is obtained. At block **1104**, an event log scanner is generated with a set of matching parameters for detecting instances of candidate risk events, based on the set of risk signatures obtained at block **1102**. For example, an event log scanner includes code deployable through a container image, as represented at block **1106**. In one example, the event log scanner includes matching logic, such a rules engine (represented at block **1108**) configured to match the set of matching parameters against event logs.

[0112] The matching parameters can include, but are not limited to, asset tags (block **1110**), actions **1112**, or other matching parameters **1114**. For example, if a risk signature is an RDS service with a

sharing operation, then the matching parameters can include an RDS service asset tag and a sharing operation action.

[0113] FIG. **12-1** illustrates rules for risk signatures, in one example. FIG. **12-2** illustrates example matching logic actions.

[0114] As shown in FIG. **12-1**, a first risk signature **1200** includes a unique signature identifier **1202** and a second risk signature **1204** includes a unique signature identifier **1206**. Each risk signature **1200**, **1204** includes a set of input criteria for matching the respective risk signature to instances of events to be identified as candidate risk events corresponding to the respective risk signature. For instance, each risk signature **1200**, **1204** identifies a service (an RDS instance snapshot in the present example) and an event name for the event to be detected in the event log. Each risk signature **1200**, **1204** also includes likelihood and impact metrics along with tags and compliance controls. In one example, when an event is identified as corresponding to a respective risk signature, the event can be assigned the likelihood and impact metrics defined in the respective risk signature.

[0115] Each risk signature **1200**, **1204** also includes matching parameters **1208** and **1210** for matching against event logs being scanned. Further, each risk signature **1200**, **1204** defines post processing actions that are triggered when instances matching the risk signatures are identified, to gather context information. As shown in FIG. **12-1**, risk signature **1200** includes actions **1212** and **1214** and risk signature **1204** includes actions **1216** and **1218**.

[0116] As can be seen in FIG. **12-1**, both risk signatures **1200** and **1204** correspond to a same type of service and event, illustratively an attribute of an RDS instance snapshot being modified. However, based on context information that is gathered based on the post processing actions, instances of events matching the risk signatures can be processed differently, by executed different action **1212/1214** and **1216/1218**. For instance, the instances of events can be assigned different likelihood and impact metrics depending on whether the attribute modification shares the RDS instance snapshot with an external account or the RDS instance snapshot is modified to be publicly accessible.

[0117] FIG. **12-2** illustrates the matching logic actions that are executed to obtain the context information depending on whether the event matches risk signature **1200** or risk signature **1204**. For instance, the action represented at reference numeral **1230** corresponds to an instance of risk signature **1200** and the action **1232** corresponds to instances that match risk signature **1204**.

[0118] Referring again to FIG. **11**, at block **1116**, cloud account permissions are obtained to launch a compute instance on the cloud account. For example, the compute instance can include a serverless function (block **1118**) (such as an AWS lambda). In one example, the compute instance is configured to use the container image provided by the orchestration engine, as represented at block **1120**. At block **1122**, the event scanner is pushed to the cloud environment using the permissions obtained at block **1106**. For example, the event log scanner can be deployed to each cloud account, and configured to run periodically in accordance with a predefined schedule, as represented at block **1124**. As shown in FIG. **10**, event log scanners **1006-1** and **1006-N** are deployed on respective cloud accounts and configured to access one or more event logs **1008**.

[0119] Referring again to FIG. **11**, at block **1126**, result metadata is received from the event log scanners at the orchestration engine **1004**. The result metadata represents candidate risk events, as represented at block **1128**. A candidate risk event illustratively includes an instance of an event from an event log that has a threshold match against a particular risk signature. Each candidate risk event can include an associated signature ID (block **1130**) that indicates which risk signature(s) the candidate risk event was matched to.

[0120] The result metadata can also include identity metadata (block **1132**), entity metadata (block **1134**), a region identifier (block **1136**), an account identifier (block **1138**), a time identifier (block **1140**), or other metadata (block **1141**).

[0121] Identity metadata can indicate a particular identity, such as a user, role, etc. corresponding to

the event identified as the candidate risk event. The identity metadata can include, for example, an asset ID that identifies the particular cloud asset (a compute resource, a storage resource, etc.) that was the target of or otherwise associated with the candidate risk event.

[0122] A region identifier can identify a particular geographic region in which the event occurred, a cloud identifier can indicate the particular cloud account within which the event was identified, and the time metadata can include a timestamp that indicates the time at which the event occurred.

[0123] One or more post-processing steps can be performed based on the result metadata. In one example, context information is obtained based on the result metadata at block **1142**. The one or more risk signatures that are used for matching parameters at block **1104** can include a post processing trigger that defines actions to be taken to obtain the context information. For example, the context information can be obtained from an infrastructure graph. Examples of infrastructure graphs are discussed above. For instance, based on the infrastructure graph, block **1142** can determine whether sensitive information was involved in the candidate risk event, as represented at block **1144**. Alternatively, or in addition, the context information can identify relationships between the services.

[0124] For sake of illustration, assume a given candidate risk even included an event that matched the risk signature (RDS service with sharing operation). The context information obtained at block **1142** can indicate whether the RDS service involved in the event included or otherwise had access to sensitive information (based on the infrastructure graph), and whether the sharing operation was with a service that was publicly accessible. In another example, the context information can identify resource configuration issues (e.g., user hasn't updated password in thirty days, user has more than one active access key, etc.).

[0125] At block **1148**, for each candidate risk event, the corresponding risk signature is applied to determine whether the candidate risk event is to be classified as an actual risk event. In one example, this includes identifying the risk signature based on the signature ID **1130**, as represented at block **1150**.

[0126] At block **1152**, other actions can be performed based on the identified risk events. For example, a user interface display can be generated at block **1154** to render the risk events detected by application of the risk signatures. Alternatively, or in addition, one or more remedial actions can be performed at block **1156**. Of course, other actions can be performed as well, as represented at block **1158**.

[0127] At block **1160**, operation determines whether the risk signatures have been updated. If so, operation can return to generate an updated event log scanner, for example through creation of a new container image, to be pushed to the cloud accounts to scan for further candidate risk events.

[0128] FIG. **13** is a flow diagram **1300** illustrating one example of operation of an event log scanner. At block **1302**, input parameters are received that define a multi-level matcher to be executed by a rules engine. For example, the input parameters can include, but are not limited to, a cloud provider, an asset/service type **1306**, a target operation **1308**, a threshold match level (**1310**), and can include other parameters **1312** as well.

[0129] At block **1314**, an event log is accessed by the scanner to apply the multi-level matcher configured based on the input parameters. In one example, the scanner performs a single pass scan of the event log at block **1316**. Illustratively, the single pass scan includes analysis of each entry in the event log only once, so that multiple passes of the event log are not required even if multiple different risk signatures are being utilized as a basis for candidate risk event detection.

[0130] For the particular log entry being considered (accessed at block **1318**), the input parameters are matched against the log entry at block **1318** and block **1320** determines whether there is a threshold match level reached. For example, assume the input parameters include AWS as the cloud provider, the asset type as an RDS service, and the target operation as a sharing operation. Block **1320** can determine whether the log entry indicates that the event at least included an RDS service within an AWS account that included an operation that shared data, for example to another

service/asset. If the threshold is reached, operation proceeds to block **1322** in which a function is called to further analyze the log entry to determine if a candidate risk event exists. A function can be configured for each different risk signature. In this way, a risk signature-specific function is called if a match threshold is reached for that given risk signature.

[0131] If a candidate risk event is determined at block **1324**, operation proceeds to block **1326** in which result metadata is obtained from the log entry. Examples of the result metadata that can be obtained is illustrated above with respect to block **1136**. At block **1328**, the result metadata is tagged with the signature identifier that uniquely identifies the particular risk signature for which the candidate risk event is detected.

[0132] At block **1330**, it is determined whether more log entries exist in the event log. If so, operation returns to block **1328** in which the input parameters are matched against the log entry.

[0133] FIG. **14** illustrates one example of a user interface display **1400**, that renders a set of tagged risk signatures. As shown in FIG. **14**, display **1400** provides a searchable interface to access, modify, add, and/or delete risk signatures that can be applied to the cloud infrastructure posture. Each risk signature defines a set of criteria that the resources and data in the cloud environment can be queries upon to identify indications of vulnerabilities in the cloud service.

[0134] The example of FIG. **14** provides the set of tagged risk signatures in a tabular format, having a plurality of rows **1402** each representing a different risk signature. Each row includes a plurality of data fields or cells arranged in a plurality of columns **1404**. The plurality of columns includes a name column **1406**, a signature ID column **1408**, a description column **1410**, a result header column **1412**, a resource column **1414**, a tags column **1416**, a breach likelihood factor column **1418**, and a breach impact factor column **1420**. Column **1406** includes a name of the given risk signature, uniquely identified by a signature ID in column **1408**. The description column **1410** describes the risk signature, and the result header column **1412** identifies the information to be returned in results that match the risk signature. The tags column **1416** identifies one or more tags, for the given risk signature. The tags identify characteristics of the resources to which the risk signature applies. For example, the tags **1422** for risk signature **1424** indicate that the risk signature is applicable to S3 resources. This, of course, is for sake of example only.

[0135] Likelihood factor column **1418** indicates a likelihood factor that is assigned to the risk signature and an impact factor column **1420** indicates an impact factor assigned to the risk signature. The likelihood factor indicates a likelihood assigned to occurrence of the risk signature and the impact factor assigns an impact to the cloud service assigned to the occurrence of the risk signature. For sake of illustration, a likelihood factor of ten (out of a scale of ten) indicates that the vulnerability is likely to occur if the risk signature is identified in the cloud posture data, whereas a likelihood factor of one indicates a low likelihood. Similarly, an impact factor of ten (out of a scale of ten) indicates that the vulnerability is considered to have a high impact, whereas an impact factor of one indicates the vulnerability is considered to have a low impact on the cloud service.

[0136] As noted above, results of the instances of matching risk signatures are outputted, for example in a user interface display. One example display is illustrated in FIG. **15**.

[0137] As shown in FIG. **15**, display **1500** includes a plurality of rows **1502** that indicate matching instances of risk signatures. Each row includes a description field in column **1504**, a resource name field in column **1506**, an account ID field in column **1508**, a tags field in column **1510**, an impact field in column **1512**, a likelihood field in column **1514**, and a signature ID field in column **1516**. The signature ID field in column **1416** identifies the signature ID that was matched by the instance identified in the row. The tags field identifies which tags were matched between the infrastructure change and the risk signature that was matched for the given row.

[0138] FIG. **16** illustrates one example of a user interface display **1600**. Display **1600** visualizes detected risk events through grouping based on categorization. In display **1600**, the columns represent various services that are running in the cloud environment and the rows represent a set of accounts associated with the user. In this way, the user can identify how many risks have been

identified in each account on a per-service basis. In this way, the user can quickly identify where the risks are concentrated in each of the user's accounts.

[0139] It can thus be seen that the present disclosure provides technology for data security posture analysis of a cloud environment that identifies risk events using activity and/or graph-based context. Further, in described examples, the features are applicable to multi-cloud environments, in that it is generic relative to any particular cloud environment. Further, the risk event detection utilizes event log scanners that are configured, and updatable, with risk signatures to execute in a manner that provides real-time or near real-time data moments as those events are detected. Further, the risk signature matching parameters operate to return those instances having a threshold level of match, and metadata is returned which reduces the computational end data processing/transmission load. Further, post-processing steps operate to supplement the candidate risk events with contextual information, for example from the infrastructure graph, which informs the risk event determination.

[0140] The present technology improves the performance in security of cloud databases in a way that maintains up-to-date posture data through reduced processing bandwidth requirements, which improves latency. The present technology improves the performance in security of cloud databases.

[0141] One or more implementations of the technology disclosed or elements thereof can be implemented in the form of a computer product, including a non-transitory computer readable storage medium with computer usable program code for performing the method steps indicated. Furthermore, one or more implementations and clauses of the technology disclosed or elements thereof can be implemented in the form of an apparatus including a memory and at least one processor that is coupled to the memory and operative to perform exemplary method steps. Yet further, in another aspect, one or more implementations and clauses of the technology disclosed or elements thereof can be implemented in the form of means for carrying out one or more of the method steps described herein; the means can include (i) hardware module(s), (ii) software module(s) executing on one or more hardware processors, or (iii) a combination of hardware and software modules; any of (i)-(iii) implement the specific techniques set forth herein, and the software modules are stored in a computer readable storage medium (or multiple such media).

[0142] Examples discussed herein include processor(s) and/or server(s). For sake of illustration, but not by limitation, the processors and/or servers include computer processors with associated memory and timing circuitry, and are functional parts of the corresponding systems or devices, and facilitate the functionality of the other components or items in those systems.

[0143] Also, user interface displays have been discussed. Examples of user interface displays can take a wide variety of forms with different user actuable input mechanisms. For instance, a user input mechanism can include icons, links, menus, text boxes, check boxes, etc., and can be actuated in a wide variety of different ways. Examples of input devices for actuating the input mechanisms include, but are not limited to, hardware devices (e.g., point and click devices, hardware buttons, switches, a joystick or keyboard, thumb switches or thumb pads, etc.) and virtual devices (e.g., virtual keyboards or other virtual actuators). For instance, a user actuable input mechanism can be actuated using a touch gesture on a touch sensitive screen. In another example, a user actuable input mechanism can be actuated using a speech command.

[0144] The present figures show a number of blocks with corresponding functionality described herein. It is noted that fewer blocks can be used, such that functionality is performed by fewer components. Also, more blocks can be used with the functionality distributed among more components. Further, the data stores discussed herein can be broken into multiple data stores. All of the data stores can be local to the systems accessing the data stores, all of the data stores can be remote, or some data stores can be local while others can be remote.

[0145] As used herein, if a description includes “one or more of” or “at least one of” followed by a list of example features with a conjunction “or” between the penultimate example feature and the last example feature, then this is to be read such that (1) one example includes at least one of or one

or more of each feature of the listed features, (2) another example includes at least one of or one or more of only one feature of the listed features, and (3) another example includes some combination of the listed features that is less than all of the features and more than one of the features.

[0146] As used herein, if a description includes “one or more of” or “at least one of” followed by a list of example features with a conjunction “and” between the penultimate example feature and the last example feature, then this is to be read such that the example includes at least one of or one or more of each feature of all the listed features.

[0147] As used herein, if a description includes “one or more of” or “at least one of” followed by a list of example features with a conjunction “and/or” between the penultimate example feature and the least example feature, then this is to be read such that, in one example, the description includes “one or more of” or “at least one of” followed by a list of example features with a conjunction “or” between the penultimate example feature and the last example feature, and, in another example, the description includes “one or more of” or “at least one of” followed by a list of example features with a conjunction “and” between the penultimate example feature and the last example feature.

[0148] The above discussion has described a variety of different systems, components, logic, and interactions. One or more of these systems, components, logic and/or interactions can be implemented by hardware, such as processors, memory, or other processing components. Some particular examples include, but are not limited to, artificial intelligence components, such as neural networks, that perform the functions associated with those systems, components, logic, and/or interactions. In addition, the systems, components, logic and/or interactions can be implemented by software that is loaded into a memory and is executed by a processor, server, or other computing component, as described below. The systems, components, logic and/or interactions can also be implemented by different combinations of hardware, software, firmware, etc., some examples of which are described below. These are some examples of different structures that can be used to implement any or all of the systems, components, logic, and/or interactions described above.

[0149] The elements of the described figures, or portions of the elements, can be disposed on a wide variety of different devices. Some of those devices include servers, desktop computers, laptop computers, tablet computers, or other mobile devices, such as palm top computers, cell phones, smart phones, multimedia players, personal digital assistants, etc.

[0150] FIG. 17 is a simplified block diagram of one example of a client device **1700**, such as a handheld or mobile device, in which the present system (or parts of the present system) can be deployed. FIG. 18 illustrates an example of a handheld or mobile device.

[0151] One or more communication links **1702** allows device **1700** to communicate with other computing devices, and can provide a channel for receiving information automatically, such as by scanning. An example includes communication protocols, such as wireless services used to provide cellular access to a network, as well as protocols that provide local wireless connections to networks.

[0152] Applications or other data can be received on an external (e.g., removable) storage device or memory that is connected to an interface **1704**. Interface **1704** and communication links **1702** communicate with one or more processors **1706** (which can include processors or servers described with respect to the figures) along a communication bus (not shown in FIG. 17), that can also be connected to memory **1708** and input/output (I/O) components **1710**, as well as clock **1712** and a location system **1714**.

[0153] Components **1710** facilitate input and output operations for device **1700**, and can include input components such as microphones, touch screens, buttons, touch sensors, optical sensors, proximity sensors, orientation sensors, accelerometers. Components **1710** can include output components such as a display device, a speaker, and or a printer port.

[0154] Clock **1712** includes, in one example, a real time clock component that outputs a time and date, and can provide timing functions for processor **1706**. Location system **1714** outputs a current

geographic location of device **1700** and can include a global positioning system (GPS) receiver, a LORAN system, a dead reckoning system, a cellular triangulation system, or other positioning system. Memory **1708** stores an operating system **1716**, network applications and corresponding configuration settings **1718**, communication configuration settings **1720**, communication drivers **1722**, and can include other items **1724**. Examples of memory **1708** include types of tangible volatile and non-volatile computer-readable memory devices. Memory **1708** can also include computer storage media that stores computer readable instructions that, when executed by processor **1706**, cause the processor to perform computer-implemented steps or functions according to the instructions. Processor **1706** can be activated by other components to facilitate functionality of those components as well.

[0155] FIG. **18** illustrates one example of a tablet computer **1800** having a display screen **1802**, such as a touch screen or a stylus or pen-enabled interface. Screen **1802** can also provide a virtual keyboard and/or can be attached to a keyboard or other user input device through a mechanism, such as a wired or wireless link. Alternatively, or in addition, computer **1800** can receive voice inputs.

[0156] FIG. **19** shows an example computer system **1900** that can be used to implement the technology disclosed. Computer system **1900** includes at least one central processing unit (CPU) **1972** that communicates with a number of peripheral devices via bus subsystem **1955**. These peripheral devices can include a storage subsystem **1910** including, for example, memory devices and a file storage subsystem **1936**, user interface input devices **1938**, user interface output devices **1976**, and a network interface subsystem **1974**. The input and output devices allow user interaction with computer system **1900**. Network interface subsystem **1974** provides an interface to outside networks, including an interface to corresponding interface devices in other computer systems.

[0157] In one implementation, cloud security posture analysis system **1918** is communicably linked to the storage subsystem **1910** and the user interface input devices **1938**.

[0158] User interface input devices **1938** can include a keyboard; pointing devices such as a mouse, trackball, touchpad, or graphics tablet; a scanner; a touch screen incorporated into the display; audio input devices such as voice recognition systems and microphones; and other types of input devices. In general, use of the term “input device” is intended to include all possible types of devices and ways to input information into computer system **1900**.

[0159] User interface output devices **1976** can include a display subsystem, a printer, a fax machine, or non-visual displays such as audio output devices. The display subsystem can include an LED display, a cathode ray tube (CRT), a flat-panel device such as a liquid crystal display (LCD), a projection device, or some other mechanism for creating a visible image. The display subsystem can also provide a non-visual display such as audio output devices. In general, use of the term “output device” is intended to include all possible types of devices and ways to output information from computer system **1900** to the user or to another machine or computer system.

[0160] Storage subsystem **1910** stores programming and data constructs that provide the functionality of some or all of the modules and methods described herein. These software modules are generally executed by processors **1978**.

[0161] Processors **1978** can be graphics processing units (GPUs), field-programmable gate arrays (FPGAs), application-specific integrated circuits (ASICs), and/or coarse-grained reconfigurable architectures (CGRAs). Processors **1978** can be hosted by a deep learning cloud platform such as Google Cloud Platform™, Xilinx™, and Cirrascale™. Examples of processors **1978** include Google's Tensor Processing Unit (TPU)™, rackmount solutions like GX4 Rackmount Series™, GX50 Rackmount Series™, NVIDIA DGX-1™, Microsoft's Stratix V FPGA™, Graphcore™ Intelligent Processor Unit (IPU)™, Qualcomm's Zeroth Platform™ with Snapdragon processors™, NVIDIA's Volta™, NVIDIA's DRIVE PX™, NVIDIA's JETSON TX1/TX2 MODULE™, Intel's Nirvana™, Movidius VPU™, Fujitsu DPI™, ARM's DynamicIQ™, IBM TrueNorth™, Lambda GPU Server with Testa V100s™, and others.

[0162] Memory subsystem **1922** used in the storage subsystem **1910** can include a number of memories including a main random access memory (RAM) **1932** for storage of instructions and data during program execution and a read only memory (ROM) **1934** in which fixed instructions are stored. A file storage subsystem **1936** can provide persistent storage for program and data files, and can include a hard disk drive, a floppy disk drive along with associated removable media, a CD-ROM drive, an optical drive, or removable media cartridges. The modules implementing the functionality of certain implementations can be stored by file storage subsystem **1936** in the storage subsystem **1910**, or in other machines accessible by the processor.

[0163] Bus subsystem **1955** provides a mechanism for letting the various components and subsystems of computer system **1900** communicate with each other as intended. Although bus subsystem **1955** is shown schematically as a single bus, alternative implementations of the bus subsystem can use multiple busses.

[0164] Computer system **1900** itself can be of varying types including a personal computer, a portable computer, a workstation, a computer terminal, a network computer, a television, a mainframe, a server farm, a widely-distributed set of loosely networked computers, or any other data processing system or user device. Due to the ever-changing nature of computers and networks, the description of computer system **1900** depicted in FIG. **19** is intended only as a specific example for purposes of illustrating the preferred implementations of the present invention. Many other configurations of computer system **1900** are possible having more or less components than the computer system depicted in FIG. **19**.

[0165] It should also be noted that the different examples described herein can be combined in different ways. That is, parts of one or more examples can be combined with parts of one or more other examples. All of this is contemplated herein.

[0166] The technology disclosed can be practiced as a system, method, or article of manufacture. One or more features of an implementation can be combined with the base implementation. Implementations that are not mutually exclusive are taught to be combinable.

[0167] One or more features of an implementation can be combined with other implementations. This disclosure periodically reminds the user of these options. Omission from some implementations of recitations that repeat these options should not be taken as limiting the combinations taught in the preceding sections-these recitations are hereby incorporated forward by reference into each of the following implementations.

[0168] Although the subject matter has been described in language specific to structural features and/or methodological acts, it is to be understood that the subject matter defined in the appended claims is not necessarily limited to the specific features or acts described above. Rather, the specific features and acts described above are disclosed as example forms of implementing the claims.

Claims

1. A computer-implemented method for detecting risk events in a cloud environment, the computer-implemented method comprising: obtaining a set of risk signature definitions, each risk signature definition, in the set of risk signature definitions, representing a corresponding risk signature; deploying an event log scanner to the cloud environment, the event log scanner configured to detect, in the cloud environment, instances of candidate risk events in accordance with the set of risk signature definitions based on a scan of an event log in the cloud environment and to label each detected instance with a signature identifier that identifies one or more risk signatures, of the set of risk signatures, that correspond to the detected instance; obtaining result metadata indicative of the detected instances of candidate risk events; accessing a cloud infrastructure graph that defines nodes that represent resources in the cloud environment and edges, between the nodes, that represent relationships between the resources; deriving context information, associated with the detected instances of candidate risk events, from the cloud infrastructure graph based on the result

metadata and one or more of the nodes or the edges; and generating an output representing a classification of one or more of the detected instances of candidate risk events as a risk event based on the context information relative to the set of risk signature definitions.

2. The computer-implemented method of claim 1, wherein deploying the event log scanner comprises deploying a container image that includes a representation of the set of risk signature definitions in the cloud environment.

3. The computer-implemented method of claim 1, wherein the event log scanner is configured to identify, in the event log, a plurality of events of different event types comprising one or more of: data creation events, data movement events, data deletion events, or data update events.

4. The computer-implemented method of claim 3, wherein the event log scanner is configured to perform event log scanning independent of the different event types.

5. The computer-implemented method of claim 1, and further comprising filtering a set of events in the event log with a set of properties.

6. The computer-implemented method of claim 5, wherein the set of properties include one or more of: resource information identifying a resource in which an event was performed, identity information identifying an identity which performed an event, or timestamp information identifying a time the event was performed.

7. The computer-implemented method of claim 6, wherein the result metadata includes a set of values corresponding to the set of properties.

8. The computer-implemented method of claim 7, and further comprising querying the cloud infrastructure graph based on the set of values corresponding to the set of properties to obtain the context information

9. The computer-implemented method of claim 8, wherein obtaining the context information comprises triggering the querying of the cloud infrastructure graph based on a post processing trigger in the one or more risk signatures.

10. The computer-implemented method of claim 9, wherein triggering the querying comprises: identifying a plurality of input criteria for a given risk signature of the one or more risk signatures; determining a number of matches between the plurality of input criteria and a scanned event in the event log; and setting the post processing trigger based on a comparison of the number of matches and a threshold.

11. The computer-implemented method of claim 10, and further comprising invoking a post processing function to obtain the context information based on a determination that the number of matches exceeds the threshold.

12. The computer-implemented method of claim 8, wherein the context information comprises an indication that the resource contains sensitive information

13. The computer-implemented method of claim 12, and further comprising setting a risk level associated with the risk event based on the indication that the resource contains sensitive information.

14. The computer-implemented method of claim 13, and further comprising setting a risk level based on a determination of a configuration issue associated with the identity.

15. A computing system comprising: at least one processor; and memory storing instructions executable by the at least one processor, wherein the instructions, when executed, cause the computing system to: obtain a set of risk signature definitions, each risk signature definition, in the set of risk signature definitions, representing a corresponding risk signature; deploy an event log scanner to a cloud environment, the event log scanner configured to detect, in the cloud environment, instances of candidate risk events in accordance with the set of risk signature definitions based on a scan of an event log in the cloud environment and to label each detected instance with a signature identifier that identifies one or more risk signatures, of the set of risk signatures, that correspond to the detected instance; obtain result metadata indicative of the detected instances of candidate risk events; access a cloud infrastructure graph that defines nodes

that represent resources in the cloud environment and edges, between the nodes, that represent relationships between the resources; derive context information, associated with the detected instances of candidate risk events, from the cloud infrastructure graph based on the result metadata and one or more of the nodes or the edges; and generate an output representing a classification of one or more of the detected instances of candidate risk events as a risk event based on the context information relative to the set of risk signature definitions.

16. The computing system of claim 15, wherein the instructions, when executed, cause the computing system to: identify a plurality of input criteria for a given risk signature of the one or more risk signatures; determine a number of matches between the plurality of input criteria and a scanned event in the event log; invoke a post processing function to obtain the context information based on a determination that the number of matches exceeds a threshold; and trigger a query of the cloud infrastructure graph based on the post processing trigger in the one or more risk signatures.

17. The computing system of claim 15, wherein the instructions, when executed, cause the computing system to: filter a set of events in the event log with a set of properties including one or more of: resource information identifying one or more resources in which the set of events were performed, identity information identifying one or more identities which performed the set of events, or timestamp information identifying one or more times the set of events were performed, wherein the result metadata includes values corresponding to the set of properties.

18. The computing system of claim 15, wherein the instructions, when executed, cause the computing system to: deploy a container image that includes a representation of the set of risk signature definitions in the cloud environment, wherein the event log scanner is configured to identify a plurality of events in the event log, the plurality of events comprising one or more of: data creation events, data movement events, data deletion events, or data update events.

19-20. (canceled)

21. A computer-readable media having computer-readable instructions stored thereon, wherein the computer-readable instructions, when executed by a computer, cause the computer to: detect an event from an event log associated with a computing environment; identify a plurality of input criteria defined by a risk signature; determine a number of matches between the plurality of input criteria and the event from the event log; based on a comparison of the number of matches and a threshold, obtain context information for the event based on an infrastructure graph that defines nodes that represent resources in the computing environment and edges, between the nodes, that represent relationships between the resources; and generate an output representing a classification of the event as a risk event based on analysis of the context information relative to the risk signature.

22. The computer-readable media of claim 21, wherein the computer-readable instructions, when executed by the computer, cause the computer to: identify the event as a candidate risk event and generate association data that associates the candidate risk event with the risk signature; query the infrastructure graph for the context information based on the association data.
